

# Evidence Semantics and Scanner Orchestration

*A public technical paper for the Salesforce Security Observatory*

Created by Luca Pacini

| Field                                     | Value                                                         |
|-------------------------------------------|---------------------------------------------------------------|
| Version                                   | 1.3                                                           |
| Publication date                          | 1 August 2026                                                 |
| Reviewed implementation baseline          | 1b32dfe0                                                      |
| Documentation publication snapshot        | f834844b                                                      |
| External verification status              | Self-attested until the sanitised source repository is public |
| Document licence                          | CC BY 4.0 (see Publication and licensing)                     |
| Intended reference implementation licence | Apache License 2.0, on sanitised source release               |

**Evidence basis notice**

The reviewed implementation baseline records the private snapshot against which the Source-established statements in this paper were checked. The documentation publication snapshot records the later state of the private repository at publication; the changes between the two are documentation and requirements only, with no production implementation files altered. Neither identifier is a public proof source. Every Source-established statement in this paper is therefore self-attested until the sanitised repository is published.

## Abstract

Security tooling becomes unreliable when it treats four different questions as though they were one: did the assessment execute, was the source available, what value did the source return, and what conclusion may safely be drawn from that value?

The Salesforce Security Observatory separates those questions. A completed process does not prove that every source was available. An empty result does not prove that the relevant population does not exist. A non-zero result does not by itself establish severity or policy breach. A control mapping does not create a compliance decision.

This paper describes a Salesforce-native, read-only assessment model in which scanner families run through a bounded asynchronous plan, retain sanitised evidence inside the subscriber organisation, distinguish successful zero results from unavailable or incomplete evidence, and expose limitations as part of the result.

### Current public support status

| Area                                                          | Public statement                                                                                             |
|---------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Architecture and evidence model                               | Source-established in the reviewed private baseline; self-attested until the sanitised repository is public. |
| Representative runtime behaviour                              | Expected or runtime-observed only where explicitly marked. No universal edition claim is made.               |
| Partial-state rendering across cards, drill-downs and exports | Expected release-gate requirement; not claimed as release-validated in this paper.                           |
| Running-user sharing, CRUD and FLS behaviour                  | Expected release-gate requirement pending exact-release-candidate persona validation.                        |
| Environment compatibility                                     | Not assessed unless a specific validated environment is explicitly named.                                    |

#### Core proposition

Nothing found and nothing assessed are not the same result.

## 1. The problem: security evidence is not a single value

A conventional dashboard often reduces a complex assessment to a count, badge or score. That compression is useful only when the path from source to interpretation remains trustworthy.

A displayed value of zero can mean that a source was successfully queried and returned no matching records. It can also mean that the source was unavailable, permissions were insufficient, a credential was not configured, a query failed, only part of a composite source was assessed, the scanner did not run, or evidence was not retained at the selected level.

- Only a successfully assessed and sufficiently complete source supports a genuine zero statement.
- Unavailable evidence must not be converted into zero.
- Incomplete evidence must not be presented as complete.
- Framework mappings support review; they do not decide compliance.

#### Integrity rule

Execution outcome, source availability, metric value and permitted interpretation are independent dimensions. A security observation is valid only when the relationship between them is explicit.

## 2. The four-dimensional evidence model

### 2.1 Dimensions

The values below are the abstract model. They are not display tokens; the rendered product vocabulary is given in 2.2.

| Dimension                | Question                                                            | Typical values                                                                     |
|--------------------------|---------------------------------------------------------------------|------------------------------------------------------------------------------------|
| Execution outcome        | Did the scanner or orchestration step reach a known terminal state? | Completed; completed with warnings; failed; not reached; not selected              |
| Source availability      | Was the required source accessible and sufficiently complete?       | Available; partial; unavailable; unsupported; not configured; not assessed         |
| Metric value             | What did the successfully assessed source return?                   | Non-zero; zero; category; date; bounded detail; no applicable value                |
| Permitted interpretation | What statement is justified by the other dimensions?                | Evidence observed; zero observed; partial or incomplete; unavailable; not assessed |

### 2.2 Abstract model and rendered product vocabulary

The evidence states in this paper are an abstract model. The product surfaces use the canonical rendered vocabulary below. Every concrete evidence condition maps to exactly one rendered state. Related abstract categories may resolve to different canonical states according to the limiting dimension. The mapping is made in the mapping layer rather than at render time. "Partial" is a completeness qualifier, not a separate product state token.

| Abstract state                     | Rendered vocabulary                                                                                             | Interpretation                                                                                        |
|------------------------------------|-----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| Evidence observed                  | Contextual metric or finding label                                                                              | A non-zero observation is shown with its source and limitation; no generic success token is required. |
| Zero observed                      | None found                                                                                                      | The assessed source completed and no matching records were observed.                                  |
| Partial or incomplete              | Count plus visible Partial qualifier and an adjacent Not assessed or Unavailable reason for the missing portion | A partial count must never look complete.                                                             |
| Scanner issue or failed assessment | Unavailable, with the safe cause appended — for example, "Unavailable — prerequisite missing"                   | Must include a safe boundary and administrator next action.                                           |
| Not run or not retained            | Not assessed; Not assessed at this evidence level; or Not captured                                              | Selected according to whether execution, evidence depth or retention is the limiting factor.          |
| Outside applicable boundary        | Not applicable                                                                                                  | Used only when the question does not apply to the organisation or feature.                            |

Review status such as "requiring review" is a property of a finding, not a state in this model. A finding is rendered with its own label and scope; it does not introduce an additional evidence state.

### 2.3 Genuine zero versus unavailable

A genuine zero requires the intended scanner family to run, the required source to be accessible, the operation to complete successfully, the source set to be complete enough for the question, no matching records to be returned, and retained evidence to distinguish that result from missing output.

Preferred wording: *No matching exposure evidence was observed within the assessed sources.* Avoid absolute claims such as *No exposure exists.*

## 3. The public scanner contract

| Condition                           | Required behaviour                                                                                   | Prohibited substitution                                                    |
|-------------------------------------|------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| Source acquisition succeeds         | Process records within the defined scope and limits.                                                 | Do not claim sources were assessed when they were not queried.             |
| Successful empty result             | Render None found with the assessed source and limitation.                                           | Do not convert a source-specific zero into an organisation-wide guarantee. |
| Source acquisition fails            | Render Unavailable with a safe cause and next action.                                                | Do not write a synthetic zero.                                             |
| Part of a composite source succeeds | Preserve usable evidence, mark the count Partial, and identify the missing category safely.          | Do not calculate or render a complete total.                               |
| Individual scanner exception        | Isolate the family where safe, retain a non-green family state, and continue independent later work. | Do not erase the failure or relabel it as empty.                           |
| Orchestration transaction failure   | Fail the assessment boundary, retain the safest available status, and stop unstated work.            | Do not present a partially executed plan as complete.                      |
| Known safe failure category         | Persist an approved bounded reason code and safe next action.                                        | Do not persist raw exceptions, stack traces or queries.                    |
| Unknown failure category            | Fail closed with a generic cause and an administrator next action.                                   | Do not invent precision.                                                   |

Expected release-gate requirement: the same contract must be enforced across cards, drill-downs, comparisons, exports and supporting framework views. This paper does not claim that every surface is already release-validated.

## 4. Evidence confidence is a ladder, not a binary claim

| Confidence level   | Meaning                                                                                                                         |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Source-established | Visible in the reviewed private implementation source. In this paper it remains self-attested until public source is available. |
| Test-observed      | Exercised by an automated test under a controlled fixture.                                                                      |
| Runtime-observed   | Occurred in a reviewed organisation execution.                                                                                  |
| Release-validated  | Passed the defined release gates on the exact release candidate.                                                                |
| Supported          | Part of the approved product contract for a stated environment and prerequisites.                                               |
| Expected           | Architecture or platform evidence suggests the behaviour, but required validation is incomplete.                                |
| Not assessed       | No reliable conclusion is available.                                                                                            |

A single successful execution is runtime evidence for that execution. It is not universal proof for every organisation of the same edition.















